Security and Reliability Specification

Authentication, Multi-Tenant Data Isolation, CORS, and Threat Modeling

1. Authentication & Token Lifecycle

DocRAG implements secure password hashing via passlib/bcrypt with salted hashes. Access tokens are short-lived (120 minutes) signed with HMAC-SHA256. Refresh tokens are tracked in the database and enforce token rotation: upon every refresh request, the previous token is marked revoked and a new unique JTI-bearing token is issued.

2. Multi-Tenant User Isolation

DocRAG enforces strict multi-tenant isolation across all endpoints and database queries. A user context is extracted from the verified JWT on every request. Documents, chunks, conversations, and messages are always scoped by user_id in SQL WHERE clauses. Tests verify that User A cannot read, update, delete, or perform vector retrieval against User B's documents.

3. Threat Model & Mitigations

Threat Vector	Impact	DocRAG Mitigation
Path Traversal	Arbitrary file read/write	_resolve_safe_path verifies canonical path within base_dir.
Prompt Injection	Model jailbreak via document	XML boundary tags & strict system role isolation.
Token Hijacking	Unauthorized session access	Short TTL access tokens + DB-tracked refresh rotation.
SQL Injection	Data exfiltration	Parameterized queries via SQLAlchemy 2.0 ORM.
Corrupted Uploads	Worker crash	Magic byte header validation before dispatch.